

WP5 Deliverable 5.2

Specification of the technical enablers for trust, security, and privacy

Sa4CPS ITEA 4 22007

Status: Final

.....

Edited by Sini Olkanen (F-Secure)

Including contributions from:

Annanda Rath (Sirris)
Pedro Faria (ISEP)
Rafael Silva (ISEP)
Hannu Lohi (Natlink)
Alpo Leinonen (Natlink)
Grégoire Moreau (ADLC)
Dilara Bayar Başlık (ACD)
Joona Vilkkö (Modirum | Gespi)
Juha Manninen (Enerim)
Lander Vanhaverbeke (Vintec)
Juhani Latvakoski (VTT)
Jussi Ronkainen (VTT)
Vesa Kyllönen (VTT)
Aleksi Talman (VTT)
Yasemin Eker (Necdet Alpata)
Feyza Nur Genç (Necdet Alpata)
[Ibrahim Arif \(ERARGE\)](#)

TABLE OF CONTENTS

Abstract.....	4
List of Abbreviations	5
1 Introduction.....	7
2 Scope and methodology	9
3 Trust, security and privacy required functionalities of the Use cases	11
3.1 <i>Trust, security and privacy in the UC1: Autonomous lightweight logistics.....</i>	11
3.2 <i>Trust, security and privacy in the UC3: Application of advanced maps in public safety.....</i>	11
3.3 <i>Trust, security and privacy in the UC4: Critical electricity distribution grid operation in energy communities.....</i>	12
3.4 <i>Trust, security and privacy in the UC5: Security and location awareness of persons.....</i>	12
3.5 <i>Trust, security and privacy in the UC7: Multirouting secure awareness system for outdoors .</i>	13
3.6 <i>Trust, security and privacy in the UC8: Drone operation control room.....</i>	13
3.7 <i>Trust, security and privacy in the UC9: Management of CPS assets.....</i>	15
3.8 <i>Trust, security and privacy required in the Project story.....</i>	15
Trust, security and privacy related technical enablers	17
3.9 <i>Identification, verification & access control</i>	17
<i>Cryptographic Trust for Software and Configuration Artifacts.....</i>	19
<i>Secure Communication Channels</i>	20
<i>Identity Management and Access Control</i>	20
<i>Verification and Safe Activation Mechanisms on the CPS.....</i>	20
<i>Auditing, Traceability and Accountability</i>	21
<i>Privacy and Data Protection</i>	21
3.10 <i>Secure information spaces, sharing & routing.....</i>	25
3.11 <i>Zero trust services with DLT infrastructures.....</i>	33
3.12 <i>Sensing of security situation.....</i>	39
3.13 <i>Credential-based trust system.....</i>	45
Conclusions	48

TABLES OF FIGURES AND TABLES

Figure 1. WP5 focus in the overall architecture.	9
Figure 3. 3AM Decentralized Backend Architecture	34
Figure 3. Trust system.....	45
Table 1 WP5 task descriptions	7
Table 2 Technical enablers for identification, verification and access control	18
Table 3 Trusted device enrollment and cloud-assisted OOB pairing related requirements	22
Table 4 Technical enablers for secure information spaces, sharing & routing	26
Table 5 Technical enablers for Zero trust services with DLT infrastructures.....	33
Table 6 UC7 related requirements for zero trust services with DLT infrastructure.....	38
Table 7 Technical enablers for sensing of security situation	40

Abstract

This deliverable specifies the technical enablers for trust, security, and privacy developed within Work Package 5 of the Sa4CPS (Secure Situational Awareness for Critical Cyber-Physical Systems) project. The document presents a comprehensive framework of trust, security and privacy mechanisms designed to ensure reliable and trustworthy situational awareness across diverse cyber-physical system applications, including autonomous logistics, drone operations, critical energy infrastructure, public safety systems, and outdoor monitoring environments in Sa4CPS concept.

The technical enablers are organized into four complementary categories: identification, verification, and access control mechanisms; secure information spaces, sharing, and routing solutions; zero-trust services with distributed ledger technology infrastructures; and security situation sensing capabilities. Additionally, a credential-based trust system is presented to support cross-organizational data exchange requirements arising from the project story scenario.

Each enabler specification includes a description of its functionality, mapping to security requirements identified in Deliverable 5.1, the use cases where it is applied, and the contributing project partners. The enablers address critical security challenges in cyber-physical systems, including authentication of devices and users, cryptographic verification of software artifacts, end-to-end encrypted communication, immutable accountability logging, anomaly detection, and privacy-preserving data processing.

Collectively, these technical enablers support secure, resilient, and privacy-respecting situational awareness in safety-critical and operationally sensitive cyber-physical environments across Sa4CPS Use Cases and project story. The specifications provided in this document serve as the foundation for design of technical enablers documented in Deliverable 5.3.

List of Abbreviations

Abbreviation	Explanation
3AM	Triangular Accountability Model
AES	Advanced Encryption Standard
AES-CCM	Advanced Encryption Standard - Counter with CBC-MAC
AI	Artificial Intelligence
API	Application Programming Interface
AWS	Amazon Web Services
CBAC	Credential-Based Access Control
CBC	Cipher Block Chaining
CID	Content Identifier
CPE	Customer Premises Equipment
CPS	Cyber-Physical System
CSV	Comma-Separated Values
DID	Decentralized Identifier
DLT	Distributed Ledger Technology
DNS	Domain Name System
DOCS	Drone Operation Control System
DSO	Distribution System Operator
EAD	Encrypted Advertising Data
EBSI	European Blockchain Services Infrastructure
ECC	Elliptic Curve Cryptography
ECDH	Elliptic Curve Diffie-Hellman
eIDAS	Electronic IDentification, Authentication and trust Services
ELK	Elasticsearch, Logstash, Kibana
GDPR	General Data Protection Regulation
GUI	Graphical user interface
HIPAA	Health Insurance Portability and Accountability Act
HRV	Heart Rate Variability
HSM	Hardware Security Module
HTTPS	Hypertext Transfer Protocol Secure
IEC	International Electrotechnical Commission
IoT	Internet of Things
IPFS	InterPlanetary File System
ISO	International Organization for Standardization
IV	Initialization Vector
JWT	JSON Web Token
KMS	Key Management Service
M2M	Machine-to-Machine
MAC	Message Authentication Code
MC	Multicommunicator
MIC	Message Integrity Check
MITM	Man-in-the-Middle

ML	Machine Learning
MQTT	Message Queuing Telemetry Transport
NFT	Non-Fungible Token
NIS2	Network and Information Security Directive 2
NoSQL	Not Only SQL
OID4VP	OpenID for verifiable presentations
OpenID4VC	OpenID for verifiable credential issuance
OOB	Out-of-Band
OPC UA	Open Platform Communications Unified Architecture
PAwR	Periodic Advertising with Responses
PCI-DSS	Payment Card Industry Data Security Standard
R&D	Research and Development
RBAC	Role-Based Access Control
REST	Representational State Transfer
RF	Radio Frequency
RS256	RSA Signature with SHA-256
Sa4CPS	Secure situational awareness for critical cyber-physical systems
SD-JWT	Selective Disclosure JSON Web Token
SDK	Software Development Kit
SitAw	Situational Awareness
TCP	Transmission Control Protocol
TLS	Transport Layer Security
ToF	Time-of-Flight
UC	Use case
UDP	User Datagram Protocol
UID	Unique Identifier
UI	User Interface
UTM	Unmanned Traffic Management
VC	Verifiable Credential
VPN	Virtual Private Network
W3C	Work Wide Web Consortium
(W)LAN	(Wireless) Local Area Network
WiFi	Wireless Fidelity
WP	Work package
ZTNA	Zero Trust Network Access

1 Introduction

This document specifies the technical enablers for trust, security, and privacy developed within Work Package 5 (WP5) of the Sa4CPS project. These enablers form the foundation for secure and trustworthy situational awareness in critical cyber-physical systems across diverse application domains in Sa4CPS concept.

WP5 focuses on the research and development (R&D) of technical enablers for digital trust, security, and privacy, with the aim of increasing the reliability of situational awareness for devices, people, and digital twins. The work addresses fundamental challenges in establishing trust relationships, securing data exchange, protecting privacy, and maintaining system integrity in distributed, heterogeneous, and safety-critical systems.

Expected results of WP5:

- Technological requirements for trust, security and privacy for situational awareness.
- Technical enablers for trust, security and privacy required in the Sa4CPS concept.
- Evaluation of the developed enablers for trust, security and privacy.

The work within WP5 is organized into four complementary tasks, as illustrated in Figure 1. Task 5.1 addresses identification, verification, and access control mechanisms. Task 5.2 focuses on secure information spaces, sharing, and routing. Task 5.3 develops zero-trust services with distributed ledger technology (DLT) infrastructures. Task 5.4 concentrates on sensing of security situations. Together, these tasks provide comprehensive coverage of trust, security, and privacy requirements across the Sa4CPS architecture.

Task	Description
Task 5.1	Identification, verification & access control [Polar, ISEP, Digitalmente, CEL, Natlink, ACD, ADLC, VTT, Sirris, Vintecc, Otokar, Enerim] (all UCs) Technical requirements and R&D of the enablers and means for identification, verification and access control.
Task 5.2	Secure information spaces, sharing & routing [ISEP, Digitalmente, CEL, Natlink, ACD, ADLC, VTT, Sirris, Vintecc, Otokar, Enerim] (all UCs) Technical requirements and R&D of the enablers and means for secure information spaces, sharing and overdelayed routing.
Task 5.3	Zero Trust services with DLT infrastructures [Érarge, ISEP, Digitalmente, CEL, Natlink, ACD, ADLC, VTT, Otokar, Enerim] (all UCs) Technical requirements and R&D of the enablers and means for zero trust services and applications with DLT infrastructures.
Task 5.4	Sensing of security situation [F-Secure, Polar, ISEP, Digitalmente, CEL, Natlink, ACD, ADLC, VTT, Otokar, Enerim] (all UCs) Technical requirements and R&D of the enablers and means of sensing of the security situation.

Table 1 WP5 task descriptions

This deliverable specifies the technical enablers developed within each task, describing their functionality, the requirements they address, their application in specific use cases, and the partners contributing to their development. The document serves as a technical reference for implementing

secure situational awareness solutions and provides the basis for the subsequent evaluation activities documented in Deliverable D5.3.

2 Scope and methodology

This deliverable focuses on the specification of technical enablers for trust, security, and privacy within the Sa4CPS architecture. The scope encompasses identification and access control mechanisms, secure data exchange and routing, zero-trust architectures with distributed ledger technologies, and security situation sensing capabilities across all use cases and the project story.

Architectural Context

Figure 1 illustrates the overall Sa4CPS concept architecture with emphasis on the WP5 focus areas. The highlighted components represent the primary architectural elements where trust, security, and privacy enablers are integrated. The figure also provides an overview of the areas where each use case contributes, indicated by colored dots corresponding to the use case identifiers shown in the top row. The yellow triangles mark areas that are specifically addressed by the project story requirements.

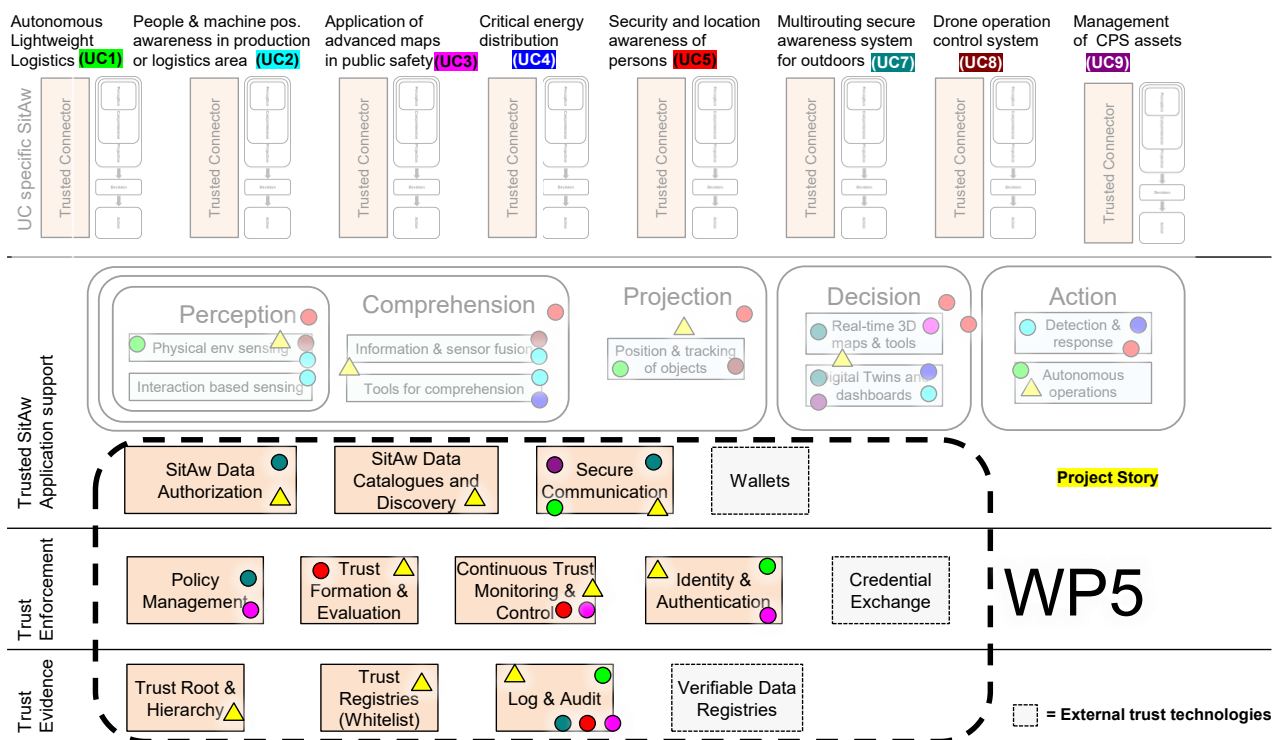


Figure 1. WP5 focus in the overall architecture.

The architectural elements within the WP5 scope address several critical security functions: data discovery and authorization mechanisms that control access to shared information; management of access policies, identities, and authentication across diverse stakeholders; and the formation, verification, and continuous monitoring of trust relationships necessary for secure data exchange in dynamic cyber-physical environments.

Methodology

The technical enablers presented in this deliverable have been developed through an iterative process that begins with the security requirements documented in Deliverable D5.1. Each use case team identified specific trust, security, and privacy challenges relevant to their operational context and developed targeted solutions to address these challenges.

The specification of each enabler follows a consistent structure:

- **Title and description:** Clear identification and explanation of the enabler's functionality
- **Addressed requirements:** Direct mapping to requirements specified in D5.1
- **Related use cases:** Identification of the use cases where the enabler is applied
- **Contributing partners:** Organizations responsible for the enabler's development and integration

This structured approach ensures traceability from requirements through implementation and facilitates the subsequent evaluation activities in WP5. The enablers are organized according to the four main WP5 tasks, reflecting the logical grouping of related security functions.

Project Story Integration

The project story presents a cross-cutting scenario that requires coordination and trust establishment between multiple use cases and external stakeholders. Section 3.8 specifically addresses the trust, security, and privacy requirements arising from the project story, identifying architectural components that play critical roles in enabling secure inter-organizational data exchange. These requirements have influenced the design of several enablers, particularly those related to credential-based trust systems and secure information sharing across organizational boundaries.

The technical enablers specified in this deliverable collectively form a comprehensive security framework that supports the Sa4CPS vision of secure, trustworthy situational awareness in critical cyber-physical systems.

3 Trust, security and privacy required functionalities of the Use cases

This chapter presents an overview of the trust, security, and privacy functionalities for each use case within the Sa4CPS project as well as for the project story. Each use case addresses specific operational contexts – ranging from autonomous logistics and public safety applications to critical infrastructure management and outdoor monitoring systems – where cyber-physical security is essential. The following sections describe how trust mechanisms, secure communication protocols, privacy-preserving techniques, and access control strategies are integrated into the respective use case architectures to ensure reliable and secure situational awareness in critical environments.

3.1 Trust, security and privacy in the UC1: Autonomous lightweight logistics

In UC1, Otokar addresses trust, security, and privacy challenges arising from autonomous and connected logistics operations within a factory environment. The use case focuses on the safe logistic of automotive parts using forklifts equipped with cameras and beacon which is transmit location data to gateway, and communication interfaces, forming a complex cyber-physical system.

Trust in the system is established by treating each forklift and its associated sensors as authenticated cyber-physical entities. Devices participating in UC1 are uniquely identified and verified before exchanging operational data. This ensures that telemetry, positioning, and safety-related information originates only from trusted sources and has not been altered during transmission.

Security is ensured through protected communication channels between forklifts, IoT gateways, and backend services. Operational data such as sensor streams, human detection events, and warning or danger states are transmitted using authenticated and encrypted links, preventing unauthorized access, spoofing, or manipulation. The architecture follows a defense-in-depth approach, combining device-level security, network protection, and backend access control mechanisms.

Privacy considerations are particularly relevant in human detection and safety monitoring scenarios. UC1 is designed to minimize personal data exposure by processing perception data locally on the forklift using edge computing components. Only abstracted events (e.g., warning or danger states) and non-identifiable metadata are shared with backend systems. This approach ensures compliance with privacy principles while maintaining operational safety.

Overall, UC1 demonstrates how trust, security, and privacy can be embedded into autonomous industrial logistics by combining secure device identity, protected data exchange, edge-based intelligence, and controlled data sharing mechanisms, aligned with the Sa4CPS trust-by-design approach.

3.2 Trust, security and privacy in the UC3: Application of advanced maps in public safety

The NSC3 system is designed to monitor live video feeds from various locations for operational safety and awareness. At the same time, safeguarding the personal privacy of individuals captured on camera

is a fundamental requirement. The system needs to utilize stringent security and privacy measures to safeguard both data, operations, and people's privacy. All communications within the system utilize secured connections to prevent interception or tampering. Video sources integrated into the platform are subject to strict verification procedures, ensuring that only trusted cameras can provide input. User access is tightly controlled: each user must not only be verified but also authenticate their identity prior to gaining entry to the system. Access rights are managed on a per-action basis, employing case-by-case authorization to guarantee that users can only perform actions for which they have explicit permission. Unauthenticated access is always strictly blocked. System access is restricted exclusively to authorized security personnel, minimizing the risk of malicious activities from external or unauthorized actors. Additionally, comprehensive audit logging is implemented throughout the system, ensuring that every user action is recorded and traceable, thereby supporting accountability and enabling effective incident response.

3.3 Trust, security and privacy in the UC4: Critical electricity distribution grid operation in energy communities

The UC4 focuses on the real-time monitoring and actuation of electrical loads within an energy community. Given the nature of the problem, the technical enablers must prevent unauthorized access to the data or the system. To ensure this, control signals must be verified and ensured they come from a reliable source and has not been modified in a harmful way. The monitoring system must provide a continuous data stream to prevent “blind” grid management. Also, the system should implement an authentication component, such as zero trust mechanism.

Regarding privacy concerns, and as the monitoring of electrical loads may reveal sensitive information due to the high frequency of the monitoring, measures such only data necessary for the operation of the grid should be transmitted to the central controller, and data should be anonymized and encrypted. Additionally, the system should incorporate mechanisms of transparency, such as verifiability and ways to certify and trust certain devices.

3.4 Trust, security and privacy in the UC5: Security and location awareness of persons

UC5 focuses on the security awareness of persons in the consumer cyber security context. Trust, security and privacy are in the core of every research activity in the use case. For instance, the user's interaction and usage of the consumer security solutions are based on trust, and this is elaborated in F-Secure Digital Perception Gap Report published in September 2025. In addition, the following privacy functionalities are central to the use case.

Data Collection and Privacy Preservation

The training of DNS fingerprint detection models requires collection of DNS query data from end-user devices. DNS query data contains the DNS names requested by devices, which is the only potentially sensitive element in our dataset. The approach employed in our pipeline explicitly disassociates individual users from collected data. Our training pipeline and model development process maintain no user identifiers or tracking information. Data aggregation operates at the device level, capturing patterns of DNS queries sent by the same device without linking these patterns to identifiable persons.

Operational Privacy Through On-Device Detection

Deployment of on-device detection models on mobile platforms enables protection features while preserving user privacy in future operational settings. By performing DNS fingerprint detection locally on-device, user data does not need to be transmitted to e.g., a cloud backend for analysis. This approach reduces the need for data transmission in production environments and avoids the privacy implications of centralized data processing. Additionally, on-device detection eliminates roundtrip latency to the cloud, enabling faster response times and improved user experience.

3.5 Trust, security and privacy in the UC7: Multirouting secure awareness system for outdoors

The UC7 focuses on the professional-grade monitoring of physiological status (such as heart rate and HRV) for groups operating in diverse and potentially hostile outdoor environments, including first responders and tactical teams. To ensure the reliability of the situational awareness in these high-stakes scenarios, the system has strict requirements for data protection, source authenticity, and resistance to tracking.

Security and Confidentiality Requirements

Given that the system broadcasts sensitive health data ("Special Category Data" under GDPR) over public radio frequencies, the technical enablers must ensure that data remains opaque to unauthorized eavesdroppers. The system requires a mechanism to encrypt data at the very edge (the sensor) before transmission. To meet this, the system must utilize the Bluetooth 5.4 Encrypted Advertising Data (EAD) standard. This enabler ensures that the payloads are encrypted with AES-CCM, safeguarding the confidentiality of the biosignals against passive listeners while maintaining the efficiency of the connectionless "Synchronized Star" topology.

Trust and Source Authentication

Reliable situational awareness depends on the certainty that data originates from valid, trusted personnel. Therefore, the system must implement a robust device enrollment process to prevent "Fake Node" injection attacks. Trust is established requires a "Trusted Enrollment" mechanism where devices cryptographically prove their identity using factory-injected ECC credentials. Furthermore, to prevent Man-in-the-Middle (MITM) attacks during the initial provisioning, the system needs to employ Cloud-Assisted Out-of-Band (OOB) pairing, ensuring that Gateways only accept connections from verified devices authorized by the backend.

Privacy and Availability

The operational nature of UC7 requires that the system protects not only the content of the data but also the presence of the individuals. The technical enablers must mitigate the risk of physical tracking via RF footprinting. This is enabled through the use of rotating session keys and identifying addresses, which impede long-term tracking by adversarial systems. Additionally, to ensure the availability and integrity of the data stream, the protocol must include freshness mechanisms (such as randomizers) to prevent replay attacks, ensuring that the situational awareness picture reflects real-time reality rather than replayed malicious data.

3.6 Trust, security and privacy in the UC8: Drone operation control room

In Use case 8, several security requirements and solutions have been investigated to ensure trust, security and privacy for the drone operation control system.

Security Frameworks and Standards

ISO 27001/02 and other regulations were used to assess the security posture of the existing ADLC's drone operation control system. The aim was to identify the security posture of the system and identify the security solutions needed to provide security and trust in the drone operation control system (DOCS). The following tasks were executed:

Using ISO-27001, a security assessment of the DOC was conducted. This covers 32 security controls such as, user's end point device, privileged access right, information access restriction, access to source code, secure authentication, capacity management, protection against malware, management of technical vulnerabilities, configuration management, information deletion, data masking, data leak prevention, information backup, secure logging, activities monitoring, secure software on operating system, application security, secure system architecture, secure coding and change management. Additionally, all the security requirements to be addressed were documented.

Security-by-design system architecture

Based on the security requirements identified above, the system solutions were investigated and integrated into the DOCS's system architecture during the design phase. The focus was on the following aspects.

First, security solutions for the communication and data sharing between different components of the system both within the DOCS and with external modules/systems were developed. Second, secure authentication for both software modules and individual users accessing and using DOCS was implemented. Third, access authorization (to different resources) for individual users and applications connecting to DOCS, based on users' roles and different types of applications and resources with different levels of sensitivities, contexts and constraints was established. Fourth, information sharing policies and rules were defined, looking at different information sharing models that fit the security requirements identified above.

Fifth, situational awareness of the drone during operation was investigated. Several situational awareness aspects were examined, such as drone flight path deviation: path deviation algorithm was developed that is able to detect drones that have deviated from their pre-defined paths both for straight-line and non-straight-line flights; drone collision detection algorithms to provide early warnings of collisions to drones in operation; and situational awareness of the drone's internal errors.

Privacy-by-design system architecture

The privacy-by-design approach incorporates data minimization and anonymization, as well as regulatory compliance.

Building operational trust

Operational trust is built through transparency dashboards, operational proficiency, and incident response.

3.7 Trust, security and privacy in the UC9: Management of CPS assets

In UC9, the management of cyber-physical system (CPS) assets is inseparably tied to trust, security, and privacy due to the critical nature of the operations executed on remote industrial devices. The Capture platform enables remote software updates, parameter modifications, and data exchange with machines that may operate continuously and autonomously. These actions inherently carry operational risks: an incorrect or maliciously altered update can destabilize a production line, degrade performance, damage equipment, or threaten human safety. Therefore, trust in the authenticity, integrity, and correctness of software and parameter changes is essential. Stakeholders (machine builders, operators, integrators, and end users) must be confident that the system enforces strict controls and executes only authorized and verified actions.

Security is equally vital because UC9 involves remote control over devices that often form the backbone of industrial operations. Cyber-physical assets have become prime targets for attacks such as spoofing, tampering, unauthorized access, and ransomware. The shift from local, isolated machines to connected, cloud-integrated systems expands the attack surface dramatically. Secure communication, strong authentication and authorization, cryptographic verification of updates, and continuous monitoring for anomalous behaviour are therefore indispensable. The system must be resilient against adversarial actions, ensuring that remote updates or parameter sets cannot be hijacked or manipulated to cause physical or economic harm.

Privacy considerations arise as CPS devices increasingly generate sensitive operational data, production metrics, performance logs, and potentially customer-specific intellectual property. In multi-tenant environments (often the case when machine builders manage fleets for different clients) data isolation and fine-grained access control are paramount. Unauthorized visibility into machine behaviour, predictive models, or update history could expose competitive information or violate contractual boundaries. Furthermore, logging and auditing mechanisms must balance traceability with the protection of privacy-sensitive metadata.

In summary, trust, security, and privacy are foundational to UC9 because remote management of CPS assets introduces both high operational impact and high cyber-risk. Ensuring that every update, parameter change, and data exchange is authenticated, verified, context-aware, and privacy-preserving is essential for safe operation, regulatory compliance, and maintaining stakeholder confidence in the Capture platform as it evolves into a secure machine control and lifecycle-management solution.

3.8 Trust, security and privacy required in the Project story

The project story covers a wide range of operations that require trusted data exchange between stakeholders. This exchange can further be divided into various tasks that either provide, rely on, or verify trust between partners. The following briefly discusses the concept architecture components that have been identified to have a role in the project story.

SitAw Data Authorization. Any data that is exchanged between partners needs to be properly authorized so that it is based on a set of predefined access conditions (credentials) that must be met. These conditions

should be controlled by the owner of the data. The project story involves exchange of data between many different systems, e.g., to obtain vehicle locations and exchange data with emergency authorities.

SitAw Data Catalogues and Discovery. To be able to locate data that each partner makes available for sharing, it is essential that a description of the data is made available to SA4CPS members as a Data Catalogue in a well-known location. This description contains, for example, a human-readable depiction of the data, required access conditions, and technical details for accessing the data. Locating available data is a core functionality needed in all data sharing involved in the project story.

Secure Communication is a fundamental requirement for all data exchange in the project story. This may include, e.g., secure communication protocols, vulnerability-aware implementation, key exchange, data integrity and non-repudiation.

Trust Formation & Evaluation. In addition to technical communication security, the ability to establish and evaluate a degree of trust in data exchange requires means to identify the communicating parties and their authorizations, attributes and context within the scope of the exchange. This becomes especially critical in transient communication contexts of the project story where trust may have to be established dynamically, without the benefit of rigorous prior screening.

Continuous Trust Monitoring & Control. In a dynamic trust environment, it is paramount to be able to constantly monitor the validity of attestations that are used as basis for trust in an operation, device, service, etc. If an attestation becomes invalid, the trusted relationship based on that needs to be terminated automatically.

Identity & Authentication. Establishing trust begins with identifying actors reliably. In the project story, actors may use different identity and authentication systems, requiring consolidation so that identities and authentication can be confirmed regardless of the underlying system.

Trust Root & Hierarchy. In the end, any attestations for establishing trust need to be anchored in some known entity that all participants recognize as a trusted source of truth. From project story point of view, the entity may be an external authority (e.g., providing identity records), or a recognized trust root within the SA4CPS context. While it is not necessary or even feasible for all attestations to be directly rooted in, e.g., a public authority, they need to be traceable to a root source of trust via an unbroken chain of trust relationships, forming a trust hierarchy.

Trust Registries (Whitelist). Formally valid attestations can technically be issued by anyone. Whitelisting trusted issuer registers ensures attestations come from recognized sources, preventing false claims or misuse of valid attestations outside their intended scope. This is especially important in the port environment of the project story, where attestations may come from diverse actors across different countries, including outside the EU.

Log & Audit. To establish traceability and accountability of trust-based interactions, every decision and action needs to be recorded so that they can be verified later. This helps detect misuse, prove compliance, and resolve disputes, especially in a dynamic environment where trust is established on the fly.

4 Trust, security and privacy related technical enablers

This chapter presents the technical enablers developed within WP5 to address the trust, security, and privacy requirements identified across the Sa4CPS use cases and project story. The enablers are organized according to the four main task areas: identification, verification and access control (Task 5.1); secure information spaces, sharing and routing (Task 5.2); zero trust services with distributed ledger technology infrastructures (Task 5.3); and sensing of security situation (Task 5.4). Additionally, a credential-based trust system is described to support the project story requirements. Each enabler specification includes a description of its functionality, the requirements it addresses from Deliverable 5.1, the relevant use cases, and the contributing partners. Together, these enablers form a security framework that supports secure situational awareness in critical cyber-physical systems.

4.1 Identification, verification & access control

This section presents the technical enablers developed under Task 5.1 for identification, verification, and access control across the Sa4CPS use cases. Secure identity management and controlled access are foundational requirements for establishing trust in cyber-physical systems, where both human users and autonomous devices must be reliably authenticated before accessing sensitive resources or performing critical operations. The enablers described below address diverse authentication and authorization challenges – from centralized user authentication services and role-based access control to device enrollment mechanisms, cryptographic verification of software artifacts, and secure communication channels.

Enabler	Contributing partners	Addressed Requirements	Related Use Case
Microservice-Based Centralized Authentication and Authorization Service	ACD	REQ_UC1.16	UC1
Downstream identity, authentication and access control integrated into the platform control plane	ADLC	REQ_UC8.34	UC8
Layered security model that combines cryptographic trust mechanisms, secure communication channels, access control, and integrity verification	Vintecc	REQ_UC9.1 REQ_UC9.2 REQ_UC9.3	UC9
Secure Scalable Group Communication via Bluetooth 5.4 PAwR	Polar	REQ_UC7.4	UC7
Trusted Device Enrollment and Cloud-Assisted OOB Pairing	Polar	REQ_UC7.3	UC7
Multicomunicator radio (LoRa) interface	Natlink	REQ_UC7.10	UC7
Multicomunicator server interface	Natlink	REQ_UC7.11	UC7

Multicomunicator IP traffic sharing	Natlink	REQ_UC7.14	UC7
Multiplace Digital Twin Specification	Natlink	REQ_UC7.25	UC7
Routing-Level Identification, Verification and Access Control Service	Alpata	REQ_UC1.16	UC1
Privacy: Protected Identity in UI and REST Security: Data Encryption	Enerim	REQ_UC4.3 REQ_UC4.4 REQ_UC4.5 REQ_UC4.6 REQ_UC4.7 REC_UC4.8	UC4
Role-Based Access Control (RBAC) & API Security Gateway	ISEP, Digitalmente	REQ_UC4.5 REQ_UC4.6 REQ_UC4.16	UC

Table 2 Technical enablers for identification, verification and access control

Microservice-Based Centralized Authentication and Authorization Service (UC1)

ACD has developed a centralized authentication and authorization service aligned with the modular architecture of the Sa4CPS system. The service is implemented using Node.js and MongoDB (NoSQL) and operates as an independent microservice.

The service provides core identity management functionalities including user registration, email-based identity verification, cryptographic password hashing, and JSON Web Token (JWT) management. During inter-service communication, the JWT included in the request header is extracted and validated via the centralized loginWithToken endpoint, allowing secure retrieval of authenticated user information.

Authorization is enforced through Role-Based Access Control (RBAC), supporting predefined roles such as admin, user, and developer. This ensures that access to system resources and APIs is strictly controlled according to assigned roles. The overall design follows a zero-trust authentication and authorization model, where each request is explicitly verified.

Requirements from D5.1 the enabler addresses:

- REQ_UC1.16 Role-Based Access Control (RBAC)

Use-case the enabler addresses

- UC1 (Autonomous lightweight logistics)

Downstream identity, authentication and access control integrated into the platform control plane (UC8)

The platform implements identification, authentication, authorisation and access control as a downstream control function, explicitly separated from the real-time situational awareness and risk processing pipeline. All perception, fusion and risk assessment functions (ingress services, worker processing, rule engine and state generation) operate independently of user identity, session state or access rights. This ensures that failures, delays or attacks targeting identity infrastructure or user-facing components cannot impair flight monitoring, abnormal situation detection or safety-critical processing, satisfying the requirement that the system remains operational and resilient even under adverse conditions.

Authentication and authorisation are enforced at the platform control plane, primarily at the boundaries where users or external systems interact with the platform (dashboards, APIs, outbound data sharing interfaces). These controls are implemented using modern cloud identity mechanisms, including multi-factor authentication for users and strong authentication for system components. Access rights are evaluated before any operational data is exposed or any control action is enabled, ensuring that only authorised actors can view or influence flight operations.

Internally, platform services do not rely on implicit trust. All inter-service communication occurs through authenticated message queues and controlled APIs. Services subscribe only to explicitly authorised data streams and cannot inject or consume operational data outside their defined role.

External data sources are either queried directly by the ingress layer or connected through explicitly authenticated and encrypted connections (e.g. TLS-protected APIs). No external system is allowed to push data into the platform without an authenticated connection and explicit acceptance by the ingress layer. This prevents the injection of unauthorised, spoofed or foreign information into the operational state.

This architecture directly mitigates the risks of unauthorised access, remote manipulation, and data injection, while preserving the independence and integrity of the safety-critical situational awareness functions and supporting the requirements for security-by-design, resilience and explainability.

UC9 technical enablers in identification, verification & access control

The SA4CPS UC9 architecture relies on a layered security model that combines cryptographic trust mechanisms, secure communication channels, access control, and integrity verification to protect cyber-physical systems against unauthorized access, tampering, and misuse. These mechanisms are designed to secure the entire lifecycle of software updates, parameter changes, and data exchange between cloud, edge, and device layers.

Cryptographic Trust for Software and Configuration Artifacts

All software update packages, container images, and configuration bundles are protected using **asymmetric cryptography** and **digital signatures**. Each artifact is signed by a trusted authority (e.g., the platform operator) using a private signing key. On the CPS or edge device, the corresponding public key is used to verify the authenticity and integrity of the artifact before installation or activation.

This mechanism ensures:

- **Authenticity:** the update originates from a trusted source
- **Integrity:** the update has not been modified in transit or storage
- **Non-repudiation:** the origin of the update can be cryptographically proven

In addition to signature verification, **cryptographic checksums (hashes)** are used to validate artifact integrity during transfer, storage, and before activation. This provides protection against corruption, partial downloads, or storage faults.

Secure Communication Channels

All communication between CPS devices, edge nodes, and cloud services is protected using **HTTPS/TLS** or equivalent secure transport layers (e.g., MQTT over TLS, OPC UA secure channels). These channels provide:

- **Confidentiality:** protection against eavesdropping
- **Integrity:** protection against message tampering
- **Endpoint authentication:** verification of both client and server identities

Identity Management and Access Control

Access to platform functions, CPS assets, and control actions is governed by **Role-Based Access Control (RBAC)**. Users, services, and devices are assigned roles that define:

- Which devices they may access
- Which operations they may perform (e.g., read data, write parameters, deploy updates)
- Under which conditions actions are permitted

This ensures strict separation of responsibilities between operators, engineers, integrators, automation services, and external systems. Access control rules are enforced consistently across cloud APIs, dashboards, update pipelines, and remote control interfaces.

Verification and Safe Activation Mechanisms on the CPS

Before any update or configuration change is applied on a CPS device, the system performs a sequence of verification steps:

- Signature validation of the artifact
- Checksum verification of the content
- Compatibility and version checks
- Optional policy and safety rule evaluation

Only after all checks pass is the new software or configuration activated. Combined with A/B deployment strategies and rollback mechanisms, this ensures that devices can always return to a known safe state if something goes wrong.

Auditing, Traceability and Accountability

All security-relevant operations – including logins, update deployments, parameter changes, and access violations – are logged in an audit trail. These logs support:

- Incident investigation
- Compliance with industrial security standards (e.g., IEC 62443, NIS2)
- Accountability of human and automated actors

Privacy and Data Protection

Operational data, digital twin state, and logs are protected using:

- Tenant isolation
- Fine-grained access control
- Encrypted storage and transport

This ensures that sensitive production data, machine behaviour, and customer-specific configurations cannot be accessed by unauthorized parties or leaked across organizational boundaries.

Secure Scalable Group Communication via Bluetooth 5.4 PAwR (UC7)

This enabler secures the high-density "Synchronized Star" topology used for outdoor monitoring. It decouples the transport layer (Bluetooth 5.4 PAwR) from the application security layer to address the specific triad of protection needs:

- **Security (Confidentiality & Integrity):** While PAwR provides the efficient transport backbone, this enabler implements a dual-path authenticated encryption scheme (using AES-CCM or similar primitives). Downlink commands are secured via Encrypted Advertising Data (EAD), while Uplink responses utilize a parallel encrypted payload structure. This ensures that all control messages and telemetry are cryptographically secure against eavesdropping and tampering.
- **Trust (Source Authenticity):** The use of authenticated encryption ensures that every packet received by the Gateway is guaranteed to originate from a valid, session-key-holding sensor. This prevents the injection of malicious or spoofed data into the situational awareness picture.
- **Privacy (Anti-Tracking & Data Protection):** Broadcasting/advertising protocols inherently risk exposing users to surveillance via their RF footprint. This enabler addresses these privacy concerns at two levels:
 - Address Anonymity: It necessitates the use of Bluetooth LE Privacy features (Resolvable Private Addresses), rotating the visible MAC addresses to prevent tracking of the device identifier.
 - Payload Anonymity: To prevent tracking via "payload content fingerprinting" (where meaningful patterns in the data reveal identity), the encryption ensures that the broadcast payload is indistinguishable from random noise. This hides sensitive biosignal data ("Special Category Data") and prevents static headers from becoming tracking beacons.

Trusted Device Enrolment and Cloud-Assisted OOB Pairing (UC7)

This enabler establishes the foundational root of trust for the entire system, ensuring that connections are only formed between verified entities. It mitigates threats during the critical "joining" phase of the device lifecycle:

- **Trust (Identity Verification):** The mechanism enforces a "Hardware-Rooted Trust" model. Devices must cryptographically prove their manufacturing identity using factory-injected credentials before they are allowed to join the fleet. This ensures the system trusts the device hardware itself, not just a software identifier.
- **Security (MITM Protection):** Risks of "Man-in-the-Middle" attacks are neutralized through Cloud-Assisted Out-of-Band (OOB) Pairing. Critical pairing secrets are never exchanged over the vulnerable local radio link but are instead delivered via a secure, mutual-TLS encrypted backhaul channel from the Cloud.
- **Privacy (Access Control):** By rigorously controlling the pairing process, this enabler prevents unauthorized "rogue" gateways from bonding with sensors. This acts as a privacy gatekeeper, ensuring that a user's health data can only ever be unlocked and retrieved by an authorized specific Gateway acting within the secure system boundary.

Related requirements from T5.1:

Req Id	Name	Description
REQ_UC7.10	Multicomunicator radio interface	Radio interface between Multicomunicator and tracking device
REQ_UC7.11	Multicomunicator server interface	Server interface from Multicomunicator to server
REQ_UC7.14	Multicomunicator IP traffic sharing	Mechanism to be WiFi router that binds IoT radio and WiFi (or bluetooth) together by giving restricted access and distance extension for mobile phone for specific data and apps.
REQ_UC7.25	Multiplace Digital Twin Specification	Create Digital Twin, of the device, dog and handheld, which is stored in Mobile app and in Server, and is Read / Write and handles user rights and flow control of the updates and visibility. Remebering that update to

Table 3 Trusted device enrollment and cloud-assisted OOB pairing related requirements

Identification

Multicomunicator radio interface: The device is identified on the radio path using a dynamic LoraID assigned by the server during registration. The server verifies the device's origin by comparing its unique UID to the production database. The owner of the LoRa device can change the LoraID at will when the encryption keys are renewed. The LoraID is transmitted in every message as part of the radio header.

Multicommunicator server interface: The MC-device is identified by the server based on its unique UID, which is verified against the production database. During registration, the server assigns a dedicated device ID to the MC-device. The MC-device acts as an independent entity responsible for its own identification and role within the system.

Multicommunicator IP traffic sharing: The MC-device acts as a WiFi router that binds the IoT radio path and local networks (WiFi or Bluetooth) together. The access point created by the MC-device is hidden by default and does not appear as a public network. Identification and connection to a phone are handled exclusively via the tracker application, ensuring that only authorized users can utilize the connection.

Multiplace Digital Twin Specification: Digital twins are created for both the tracking device (dog) and the MC-device (handheld). These twins are stored synchronously in the mobile app and on the server. Each twin is identified by a unique MC-ID and LoraID, allowing the system to differentiate the status, location, and settings of each device.

Verification

Multicommunicator radio interface: Message integrity is ensured using an Authentication Tag within the AES-CCM mode. Authentication is based on a nonce that combines a sequence number derived from GPS time with an implicit day counter. By tying the sequence number directly to GPS time, the system prevents replay attacks and ensures message freshness without needing to store state information. This process confirms both the timing of the transmission and that the sender possesses the correct encryption key.

Multicommunicator server interface: Secret session keys are securely established using the **ECDH protocol**, ensuring that actual keys are never transmitted over the network. The server authenticates all traffic based on these dynamically generated keys to ensure message integrity. This guarantees that communication between the MC-device and the server is protected against eavesdropping and tampering.

Multicommunicator IP traffic sharing: The connection provides restricted access to network services and acts as a distance extension for the mobile device. Traffic is verified at the application level, and the MC-device prioritizes tracker service data over all other traffic. This guarantees the transmission of critical tracking data even when network connectivity is limited or congested.

Multiplace Digital Twin Specification: The system manages update flow control and ensures that state changes are synchronized in real-time between the mobile app and the server. The validity of messages and state changes is verified using session-specific keys, guaranteeing that only valid updates in the correct logical order are committed to the twin's state.

Access control

Multicommunicator radio interface: Access to the system is restricted to devices whose unique identifiers have been verified against the production database prior to registration. Devices generate their own encryption keys during the registration process, ensuring that only authorized devices can encrypt and decrypt messages. Access control is further strengthened by the owner's ability to renew keys and change the device identifier as needed. This model prevents unauthorized devices from joining the network and ensures that communication remains strictly between the intended parties.

Multicomunicator server interface: Access to the server interface is granted only to MC-devices that have successfully completed the ECDH key exchange and registration. The MC-device independently manages its connection to the server, and access can be revoked on a per-device basis if key verification fails. This separates the access control of the MC-device from other devices.

Multicomunicator IP traffic sharing: Access control is strictly limited: the MC-device allows access only to specified data types and applications. The routing mechanism is closed such that general internet browsing is blocked or restricted, and resources are primarily reserved for tracker application communication. This prevents unauthorized use and ensures that system resources are sufficient for the primary task.

Multiplace Digital Twin Specification: The digital twin manages user rights and data visibility through Read/Write permissions. Only the authorized owner can modify device settings (Write), while other users may be granted restricted read access (Read) to data such as location. This ensures that access control and security remain consistent across all interfaces.

Routing-Level Identification, Verification and Access Control Service (UC1)

ALPATA has implemented identification and access control mechanisms at the routing and vehicle-coordination service level. Instead of focusing on user authentication, the enabler controls which system components are authorized to provide input to routing decisions.

Vehicle instances, IoT gateways, and backend optimization services are treated as identifiable system entities. Each routing-related message is verified before being accepted by the optimization engine. Only authorized components are allowed to submit vehicle status updates or influence route computation.

Access control rules ensure that routing decisions can be triggered only by trusted backend services, while vehicles are restricted to reporting their own operational data. This prevents unauthorized components from injecting or manipulating routing commands in safety-critical logistics operations.

Requirements from D5.1 addressed
REQ_UC1.16 – Role-Based Access Control

Use-case addressed
UC1 – Autonomous Lightweight Logistics

Privacy: Protected Identity in UI and REST (UC4)

EnerimCIS implementation for protected identity customers to ensure that only authorized users can view and manage these customers. The implementation shall encompass processes, user interface views, customer documents, invoices, and REST APIs.

Security: Data Encryption (UC4)

Encrypting data in transit is a fundamental security measure to protect sensitive information and maintain the trust and integrity of communication systems for several reasons:

- Confidentiality: Encryption ensures that sensitive data remains confidential while being transmitted over networks. Unauthorized parties cannot read the data without the decryption key.

- **Integrity:** Encryption helps protect data from being altered or tampered with during transmission. It ensures that the data received is the same as the data sent.
- **Authentication:** Encryption can help verify the identity of the parties involved in the communication, ensuring that data is being sent and received by the intended parties.
- **Compliance:** Many industries have regulations and standards (such as GDPR, HIPAA, and PCI-DSS) that require encryption of data in transit to protect sensitive information.
- **Protection Against Attacks:** Encryption helps protect against various types of cyber attacks, such as man-in-the-middle attacks, eavesdropping, and data breaches.

We will enhance the security of EnerimCIS by encrypting data in transit between EnerimCIS UI and Facade.Main backend.

Role-Based Access Control (RBAC) & API Security Gateway (UC4)

This enabler centralizes user and entity management. It ensures that only authorized DSO (Distribution System Operator) personnel or community managers can actuate loads or access granular consumption data. It utilizes OAuth2/OpenID Connect protocols for secure REST API communication.

4.2 Secure information spaces, sharing & routing

This section presents the technical enablers developed under Task 5.2 for secure information spaces, sharing, and routing. In distributed cyber-physical systems, data must flow securely between heterogeneous components – including IoT devices, edge nodes, cloud services, and external stakeholders – while maintaining confidentiality, integrity, and controlled access. The enablers described below address the challenges of creating isolated information spaces, implementing end-to-end encryption for data exchange, managing tenant separation in multi-user environments, and ensuring secure routing of operational data across complex network topologies. These mechanisms are essential for preventing data leakage, unauthorized interception, and man-in-the-middle attacks, while supporting resilient and trustworthy information sharing in safety-critical and privacy-sensitive operational contexts.

Enabler	Contributing partners	Addressed Requirements	Related Use Case
End-to-end encrypted routing	Vintecc	REQ_UC9.1 REQ_UC9.2	UC9
Separate databases per tenant	Vintecc	REQ_UC9.1 REQ_UC9.2	UC9
Decentralized Distributed Data Storage Using a Private IPFS Network	ACD	REQ_UC1.12, REQ_UC1.15	UC1
Drone operations control system	ADLC	REQ_UC8.26, REQ_UC8.28, REQ_UC8.29	UC8
Secure Routing Data Exchange and Trusted Route Update Mechanism	ALPATA	REQ_UC1.12, REQ_UC1.15	UC1

Protected Identity in UI and REST	Enerim	REQ_UC4.3, REQ_UC4.4 REQ_UC4.5, REQ_UC4.6 REQ_UC4.7, REC_UC4.8	UC4
Security: Data Encryption	Enerim	REQ_UC4.3, REQ_UC4.4 REQ_UC4.5, REQ_UC4.6 REQ_UC4.7, REC_UC4.8	UC4
End-to-End Encrypted Data Pipeline	ISEP	REQ_UC4.4, REQ_UC4.10 REQ_UC4.14	UC4
Multiplace Digital Twin and history	Natlink	REQ_UC7.1, REQ_UC7.10 REQ_UC7.11, REQ_UC7.14 REQ_UC7.20, REQ_UC7.25 REQ_UC7.27	UC7
Multicomunicator radio interface	Natlink	REQ_UC7.1, REQ_UC7.10, REQ_UC7.11, REQ_UC7.14 REQ_UC7.20, REQ_UC7.25 REQ_UC7.27	UC7

Table 4 Technical enablers for secure information spaces, sharing & routing

End-to-end encrypted routing (UC9)

Description:

End-to-end encrypted routing is a fundamental enabler for secure device telemetry, software updates, and command execution because it ensures that data remains confidential and tamper-proof across the entire communication path between cloud services, edge nodes, and cyber-physical devices. By encrypting data at the source and only decrypting it at the intended destination, the system prevents intermediate network components, brokers, or gateways from inspecting or modifying sensitive information such as operational data, control commands, or update packages. This guarantees **confidentiality**, **integrity**, and **authenticity** of telemetry streams, update instructions, and control actions, and protects the system against eavesdropping, man-in-the-middle attacks, message injection, and replay attacks. As a result, end-to-end encrypted routing establishes a trustworthy communication foundation for safe remote monitoring, controlled actuation, and reliable lifecycle management of CPS assets.

Related requirements: **REQ_UC9.1, REQ_UC9.2**

Related UCs: UC9

Contributing partner: Vintec

Separate databases per tenant (UC9)

Description:

Using a **separate database per tenant** is a key enabler for secure device telemetry, software updates, and command execution because it enforces **strong isolation boundaries** between different customers, machine fleets, or organizational domains. This prevents accidental data leakage, cross-tenant access, and privilege escalation, ensuring that device data, digital twin state, update artifacts, and command histories of one tenant can never be accessed or affected by another. Strong data isolation also limits the blast radius of security incidents, simplifies access control and auditing, and supports compliance with data protection and contractual confidentiality requirements. As a result, per-tenant databases provide a robust foundation for trustworthy multi-tenant CPS management platforms.

Related requirements: **REQ_UC9.1, REQ_UC9.2**

Related UCs: UC9

Contributing partner: Vintec

Decentralized Distributed Data Storage Using a Private IPFS Network (UC1)

Description: Telemetry and sensor data collected from vehicles via the MQTT protocol are first transmitted to an ELK Stack (Elasticsearch, Logstash, Kibana) infrastructure for real-time ingestion and analysis. At the end of each day, the accumulated data are exported in CSV format and transferred to the InterPlanetary File System (IPFS) for long-term storage.

The IPFS infrastructure is deployed as a private network running on Docker containers, isolating the system from the risks associated with public IPFS networks. Data are managed using content-addressed storage, where each file is identified by a cryptographic Content Identifier (CID).

This approach removes dependency on a single centralized server, improves availability through distributed storage, and enables secure data sharing while maintaining strong integrity guarantees.

Related requirements: REQ_UC1.12, REQ_UC1.15

Related UCs: UC1

Contributing partner: ACD

Drone operations control system (UC8)

Description: The platform implements secure information spaces and controlled data sharing through its event-driven architecture based on message queues. All operational information (telemetry, environmental data, alerts, risk scores, and state updates) is exchanged via explicitly defined data streams, rather than direct point-to-point connections.

Each topic represents a logical information space (e.g. telemetry streams, alert streams, state streams), and only authorised internal services are allowed to publish to or subscribe from each space. This enforces separation of concerns, prevents unintended data propagation, and limits the impact of faults or compromises in individual components.

External information sharing (e.g. with UTM or authorities) is implemented through dedicated outbound adapters that subscribe to internal state streams and export only the necessary subset of information to third parties. This ensures data minimisation, prevents leakage of sensitive internal data, and establishes a clear trust boundary between the platform and external systems.

The asynchronous and buffered nature of the messaging infrastructure also supports the requirement for soft real-time and resilient operation. Temporary delays, partial outages or overloads in one component do not immediately cascade into system-wide failures, allowing the platform to continue operating and to degrade gracefully in adverse conditions.

This enabler directly mitigates the risks of man-in-the-middle attacks, data leakage and unsafe coupling between components, and supports the requirement for secure, reliable and resilient information exchange.

Related requirements: REQ_UC8.26, REQ_UC8.28, REQ_UC8.29

Related UCs: UC8

Contributing partner: ADLC

Secure Routing Data Exchange and Trusted Route Update Mechanism (UC1)

Description: ALPATA has implemented a secure information sharing approach focused on routing and vehicle coordination services within UC1. The enabler ensures that routing-related data are exchanged only between authorized system components and within well-defined information spaces.

Real-time vehicle status data, such as location and operational indicators, are transmitted from vehicles and IoT gateways to backend routing and optimization services through protected communication channels. Vehicles are restricted to reporting their own operational data and cannot access routing information belonging to other vehicles or system components.

Route computation and route update messages are generated exclusively by trusted backend optimization services. These routing decisions are distributed to vehicles in a controlled manner, preventing unauthorized entities from injecting, modifying, or replaying routing commands.

By separating data producers (vehicles), decision-making components (optimization services), and data consumers (vehicles receiving route updates), the system establishes secure and isolated routing information flows. This approach improves resilience against data manipulation, supports safe coordination of autonomous logistics assets, and preserves the integrity of routing decisions in safety-critical logistics operations.

Related requirements: REQ_UC1.12, REQ_UC1.15

Related UCs: UC1

Contributing partner: ALPATA

Protected Identity in UI and REST (UC4)

Description: EnerimCIS implementation for protected identity customers to ensure that only authorized users can view and manage these customers. The implementation shall encompass processes, user interface views, customer documents, invoices, and REST APIs.

Related requirements: REQ_UC4.3, REQ_UC4.4, REQ_UC4.5, REQ_UC4.6, REQ_UC4.7, REC_UC4.8

Related UCs: UC4

Contributing partner: Enerim

Security: Data Encryption (UC4)

Description: Encrypting data in transit is a fundamental security measure to protect sensitive information and maintain the trust and integrity of communication systems for several reasons:

- Confidentiality: Encryption ensures that sensitive data remains confidential while being transmitted over networks. Unauthorized parties cannot read the data without the decryption key.
- Integrity: Encryption helps protect data from being altered or tampered with during transmission. It ensures that the data received is the same as the data sent.
- Authentication: Encryption can help verify the identity of the parties involved in the communication, ensuring that data is being sent and received by the intended parties.
- Compliance: Many industries have regulations and standards (such as GDPR, HIPAA, and PCI-DSS) that require encryption of data in transit to protect sensitive information.
- Protection Against Attacks: Encryption helps protect against various types of cyber attacks, such as man-in-the-middle attacks, eavesdropping, and data breaches.

We will enhance the security of EnerimCIS by encrypting data in transit between EnerimCIS UI and Facade.Main backend.

Related requirements: REQ_UC4.3, REQ_UC4.4, REQ_UC4.5, REQ_UC4.6, REQ_UC4.7, REC_UC4.8

Related UCs: UC4

Contributing partner: Enerim

End-to-End Encrypted Data Pipeline (UC4)

Description: Focuses on securing the communication channel between IoT sensors at the grid edge and the central management system. It ensures that "Database connections everywhere" are encrypted using TLS 1.3 and that data in transit remains confidential from interception.

Related requirements: REQ_UC4.4, REQ_UC4.10, REQ_UC4.14

Related UCs: UC4

Contributing partner: ISEP

Multicomunicator radio interface (UC7)

Description: The MC-device receives packets from the tracking device and buffers them directly into RAM. The data is kept isolated from other device processes within the buffer and is cleared as soon as the forwarding is confirmed.

The radio link shares tracking data and commands between devices. The MC-device acts as a "passive" distributor: it does not decrypt the packets but keeps them in the buffer completely unchanged (transparent) before transferring them forward.

The Multicomunicator radio interface receives encrypted data from tracking devices. Data is forwarded to mobile clients transparently by Multicomunicator. Mobile clients must have correct key to open the data. If key is wrong, then data is unknown. Sharing data to other clients is sharing keys, Owner can share key to other clients, which then can open the data. If owner changes key to device then data encryption changes and others can not open the data. Correct keys can be shared via mobile data connection e.g. via teams or in offline e.g. via QR codes.

Routing occurs through the RAM buffer, from which packets are forwarded as is (transparent routing) to either the server or the client application. This ensures the original message remains intact and encrypted all the way from the tracking device to the final recipient.

Besides forwarding data from devices to clients via Bluetooth, Multicomunicator also forwards same data to server, where server must know how to open the data and store it to database and share it to allowed users.

Related requirements: REQ_UC7.1, REQ_UC7.10

Related UCs: UC7

Contributing partner: Natlink

Multicomunicator server interface (UC7)

Description: Communication between the MC-device and the server is based on packet-level encryption. The MC-device stores its own device-specific encryption keys for the server connection in the device's secure-storage area. Keys are fetched into RAM only during processing, ensuring both persistence and protection.

Data is shared over UDP or TCP protocols, but each packet is independently encrypted using a mechanism similar to that of LoRa devices. This ensures that even if the transport layer (UDP/TCP) is open, the content itself remains protected.

The MC-device routes the transparent LoRa packets held in the RAM buffer to the server as part of the secured server traffic. Routing maintains the integrity of the original packets, and the server is able to distinguish between the MC-device's own encrypted data and the relayed LoRa data.

Related requirements: REQ_UC7.1, REQ_UC7.11

Related UCs: UC7

Contributing partner: Natlink

Multicomunicator IP traffic sharing (UC7)

Description: The MC-device creates a secure and hidden WiFi access point, with credentials stored in the device's secure-storage. The phone's tracker app receives these credentials through a secure handshake, ensuring the connection interval is isolated from other network traffic.

The MC-device shares the network connection with the phone on a restricted basis. It permits traffic only for specific tracker service applications and data types. This "white-list" ensures that radio resources are not wasted on background processes but are shared only for transmitting critical tracking data.

The MC-device routes traffic between the WiFi/Bluetooth interface and the IoT radio. Routing is prioritized: tracker app data always takes precedence over any other potential IP traffic. The MC-device acts as an intelligent bridge, providing distance extension for the phone by utilizing the MC-device's superior radio antennas.

Related requirements: REQ_UC7.1, REQ_UC7.14

Related UCs: UC7

Contributing partner: Natlink

Transfer media Optimized data traffic between components (UC7)

Description: Only the most critical information, such as encryption keys and device settings, is stored in Secure Flash. All relayed tracking data is held in RAM and cleared immediately after transmission. This minimizes Flash wear and maximizes security.

Only the most critical information, such as encryption keys and device settings, is stored in Secure Flash. All relayed tracking data is held in RAM and cleared immediately after transmission. This minimizes Flash wear and maximizes security.

Routing is transparent. Since the data is already bit-level compressed and encrypted, it passes through the MC-device extremely quickly. The MC-device does not alter or decompress this packet but forwards it as is, minimizing latency.

Related requirements: REQ_UC7.1, REQ_UC7.20

Related UCs: UC7

Contributing partner: Natlink

Multiplace Digital Twin and history (UC7)

Description: The information space is hosted in a secure server environment, with access protected by standard Natlink mechanisms outside the scope of this project. Digital twin data is linked to profiles for dogs or people, and only authorised users can access or modify information. New users cannot view historical data from previous owners, while service personnel retain full access for support and maintenance. This structure ensures privacy, secure collaboration, and proper access controls. Digital twin in Phone is protected by normal Firebase technologies, which is connected to user account. In project also other Digital twins can be studied but cannot be specified in this phase.

Related requirements: REQ_UC7.1, REQ_UC7.25, REQ_UC7.27

Related UCs: UC7

Contributing partner: Natlink

4.3 Zero trust services with DLT infrastructures

This section specifies the technical enablers developed under Task 5.3 for realizing zero-trust security models and distributed ledger-based infrastructures in Use Case 1 (UC1), Use Case 4 (UC4) and Use Case 8 (UC8). These enablers target risks identified in D5.1 related to unauthorized access, data integrity, traceability, and secure cross-entity communication in cyber-physical logistics environments.

The following enablers are presented with their descriptions, addressed requirements, relevance to UC1, UC4 and UC8, and contributing partners.

Enabler	Contributing partners	Addressed Requirements	Related Use Case
Triangular Accountability Model (3AM) Decentralized Backend	ERARGE, OTOKAR	REQ_UC1.26 REQ_UC1.28	UC1
Secure Zero-Trust Authentication and Data Infrastructure	ERARGE, OTOKAR	REQ_UC1.24 REQ_UC1.25 REQ_UC1.27 REQ_UC1.28	UC1
Blockchain-Based Proof Layer with Immutable CID Registration	ACD	REQ_UC1.36 REQ_UC1.37	UC1
Explicit validation, isolation and traceable processing across distributed services	ADLC	REQ_UC8.31	UC 8
Verifiable Route Decision Flow	ALPATA	REQ_UC1.16 REQ_UC1.12 REQ_UC1.15	UC1
Privacy: Protected Identity in UI and REST Security: Data Encryption	Enerim	REQ_UC4.3 REQ_UC4.4 REQ_UC4.5 REQ_UC4.6 REQ_UC4.7 REC_UC4.8	UC4
Identity-driven communication infrastructure	ISEP	REQ_UC4.2 REQ_UC4.4 REQ_UC4.8 REQ_UC4.12	UC4

Table 5 Technical enablers for Zero trust services with DLT infrastructures

Triangular Accountability Model (3AM) Decentralized Backend (UC1)

The Triangular Accountability Model (3AM) backend provides blockchain-based logging and verification of operational actions within UC1. It ensures immutability and traceability of events such as task assignments, route changes, and cargo handovers, using a permissioned Hyperledger Besu network.

Key components include:

- **PRIGM HSM:** Handles secure key generation and digital signatures.
- **SGW-3 (Secure Gateway):** Transmits authenticated messages from forklifts and other CPS nodes.
- **CANAT:** Ensures tamper-proof, authenticated access at vehicle level.

The backend implements a signer/verifier pattern for operational data, where each transaction is:

1. Authenticated via HSM-generated signature.
2. Transmitted securely through SGW-3.
3. Registered immutably on the blockchain.

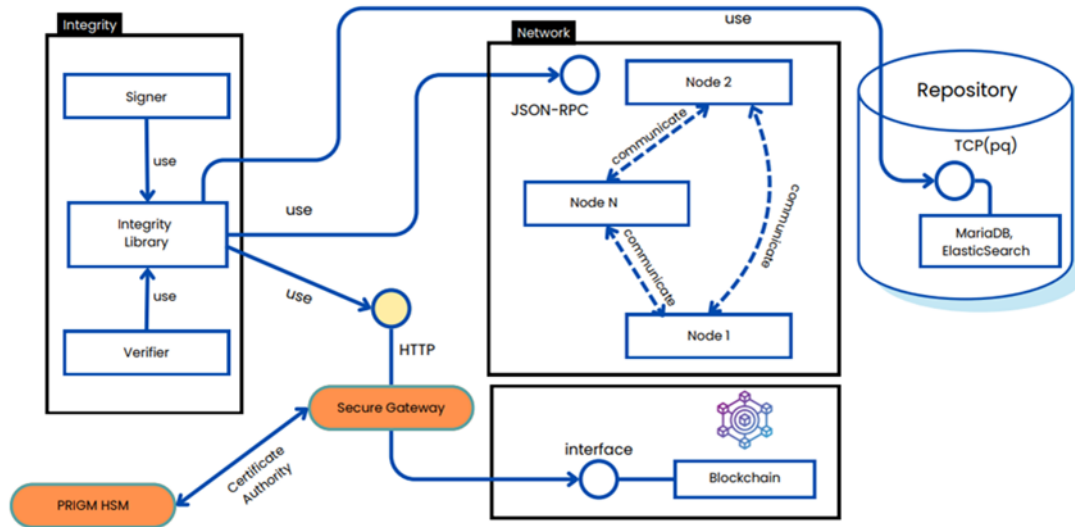


Figure 3. 3AM Decentralized Backend Architecture

Real-time constraints are supported through lightweight smart contracts optimized for <1 ms transaction latency. The enabler is aligned with EBSI principles and supports the use of decentralized identifiers (DIDs) and verifiable credentials (VCs) for identity proofing.

Addressed Requirements from D5.1:

- REQ_UC1.26 - Accountability of operations over a decentralized network
- REQ_UC1.28 - Secure transmission of sensitive data

Use Case Addressed: UC1 - Autonomous Logistics with Forklifts

Partners Contributing: ERARGE, OTOKAR

Secure Zero-Trust Authentication and Data Infrastructure (UC1)

This enabler establishes a secure-by-design identity and access infrastructure for UC1 based on zero-trust principles. It integrates hardware and software components to authenticate users, services, and devices using dynamic policies and one-time password generation. A coordinated architecture between secure gateways and HSMs enforces confidentiality and fine-grained access control.

Components:

- **Hyperledger BESU + Soulbound NFT-based RBAC Service:** Manages roles and access policies.
- **SGW-3 + PRIGM HSM Coordination:** Jointly validate identities and authorize data exchange.
- **Secure M2M Channels:** All IoT-forklift-cloud communications are encrypted and authenticated.

The infrastructure also enables secure storage of sensitive telemetry and command data using hash-based integrity verification and encrypted storage backends. Timing guarantees (e.g., <1s for network transmission) are enforced through event queue monitoring and telemetry buffering.

Addressed Requirements from D5.1:

- REQ_UC1.24 - Zero-trust user authentication and authorization
- REQ_UC1.25 - Zero-trust device identity verification (node authentication)
- REQ_UC1.27 - Secure storage of sensitive data
- REQ_UC1.28 - Secure transmission of sensitive data

Use Case Addressed: UC1 - Autonomous Logistics with Forklifts

Partners Contributing: ERARGE, OTOKAR

Blockchain-Based Proof Layer with Immutable CID Registration (UC1)

For every data file stored on IPFS, the corresponding CID is recorded on a private blockchain network based on Hyperledger Besu. Instead of storing the data itself, the blockchain stores only the CID values, preserving scalability while ensuring immutability.

Each on-chain CID record provides a verifiable timestamp and guarantees traceability of the data's existence and integrity. Any retrieved dataset can be validated by recalculating its CID and comparing it with the blockchain record.

This mechanism enforces a zero-trust data verification model, where data integrity is continuously verified rather than implicitly trusted.

Use-case the enabler addresses

- UC1 (Autonomous lightweight logistics)

The Triangular Accountability Model (3AM) backend, the secure zero-trust authentication and data infrastructure, and the blockchain-based CID proof layer work in a complementary manner to establish a robust trust and accountability framework within UC1. While the 3AM backend ensures immutability and verifiable logging of operational actions, the zero-trust infrastructure secures identity, access, and data flows across cyber-physical components. The CID proof layer further reinforces data integrity by enabling verifiable, tamper-evident referencing of shared datasets. Together, these enablers provide a cohesive foundation for secure, traceable, and trustworthy logistics operations in decentralized environments.

Explicit validation, isolation and traceable processing across distributed services (UC8)

The drone operations monitoring platform applies zero-trust principles by ensuring that no data source or internal service is implicitly trusted. All incoming data—whether from onboard systems, ground sensors or external services—is normalised, validated and checked for consistency and plausibility within the ingress and worker processing layers before it is used for situational awareness or risk assessment.

Worker services and the rule engine continuously detect missing, delayed or inconsistent data and treat such conditions as operationally relevant events, preventing degraded or manipulated inputs from silently influencing safety-critical outputs. Inter-service communication is restricted to authenticated messaging and controlled APIs, and services are functionally isolated to limit the impact of faults or compromise.

All derived operational states, alerts and risk evaluations are persisted, enabling full traceability and post-event explainability. While no distributed ledger infrastructure is used, this architecture achieves the core zero-trust objectives of verification, isolation and accountability across distributed services.

Verifiable Route Decision Flow (UC1)

ALPATA has implemented a zero-trust service-level security enabler within its ML-based routing and vehicle coordination platform. Instead of relying on implicit trust between system components, routing decisions and vehicle coordination actions are executed only after explicit verification of the requesting entity and its authorization level.

All routing-related system components, including vehicle instances, IoT gateways, and backend optimization services, are treated as identifiable and verifiable system entities. Each routing message and status update is validated at the service boundary before being processed by the routing engine. Unauthorized components are prevented from submitting vehicle state updates or influencing route computation.

Access control policies enforce strict separation of responsibilities. Vehicles are permitted only to report their own operational and location data, while route computation and route update commands can be triggered exclusively by trusted backend optimization services. This prevents unauthorized message injection, route manipulation, and unsafe control actions in safety-critical logistics environments.

The enabler follows zero-trust principles by continuously validating message origin, authorization, and context rather than assuming trust based on network location or component identity. This approach ensures secure, traceable, and controlled routing operations across distributed cyber-physical logistics systems.

Requirements from D5.1 addressed

REQ_UC1.16 – Role-Based Access Control

REQ_UC1.12 – Secure Communication for Forklifts

REQ_UC1.15 – Secure IoT Data Infrastructure

Use-case addressed

UC1 – Autonomous lightweight logistics

Privacy: Protected Identity in UI and REST (UC4)

EnerimCIS implementation for protected identity customers to ensure that only authorized users can view and manage these customers. The implementation shall encompass processes, user interface views, customer documents, invoices, and REST APIs.

Related requirements from D5.3:

- REQ_UC4.3 Data storage security for sensitive data
- REQ_UC4.4 Database connections everywhere encrypted
- REQ_UC4.5 Protected data management via REST API calls

- REQ_UC4.6 User Management Improvements
- REQ_UC4.7 Energy Community management
- REC_UC4.8 Data availability

Related Use case: UC4

Security: Data Encryption (UC4)

Encrypting data in transit is a fundamental security measure to protect sensitive information and maintain the trust and integrity of communication systems for several reasons:

- Confidentiality: Encryption ensures that sensitive data remains confidential while being transmitted over networks. Unauthorized parties cannot read the data without the decryption key.
- Integrity: Encryption helps protect data from being altered or tampered with during transmission. It ensures that the data received is the same as the data sent.
- Authentication: Encryption can help verify the identity of the parties involved in the communication, ensuring that data is being sent and received by the intended parties.
- Compliance: Many industries have regulations and standards (such as GDPR, HIPAA, and PCI-DSS) that require encryption of data in transit to protect sensitive information.
- Protection Against Attacks: Encryption helps protect against various types of cyber attacks, such as man-in-the-middle attacks, eavesdropping, and data breaches.

We will enhance the security of EnerimCIS by encrypting data in transit between EnerimCIS UI and Facade.Main backend.

Related requirements from D5.3:

- REQ_UC4.3 Data storage security for sensitive data
- REQ_UC4.4 Database connections everywhere encrypted
- REQ_UC4.5 Protected data management via REST API calls
- REQ_UC4.6 User Management Improvements
- REQ_UC4.7 Energy Community management
- REC_UC4.8 Data availability

Related Use case: UC4

Identity-driven communication infrastructure (UC4)

This enabler implements a Zero Trust Network Access (ZTNA) model using high-performance, state-of-the-art cryptographic tunneling. Instead of a traditional perimeter-based VPN, it creates a peer-to-peer mesh network where every distributed machine (IoT gateway, DSO server, and database) is assigned a unique cryptographic identity. Traffic is only allowed between specific authenticated peers using a coordinate-based routing system.

Related requirements from D5.1:

- REQ_UC4.2 Data availability (System)
- REQ_UC4.4 Database connections everywhere encrypted
- REQ_UC4.8 Data availability (End User)

- REQ_UC4.12 DSO signal of flexibility

Related use case: UC4

Zero trust services with DLT infrastructures in UC7

Table 6 lists UC7 related requirements to zero trust services with DLT infrastructure.

Req Id	Name	Description
REQ_UC7.1	Cybersecurity	Data should be secure, at least AES-128 level and data transfer messages shall not have overhead
REQ_UC7.1 0	Multicomunicator radio interface	Radio interface between Multicomunicator and tracking device
REQ_UC7.1 1	Multicomunicator server interface	Server interface from Multicomunicator to server Mechanism to be WiFi router that binds IoT radio and WiFi (or bluetooth) together by giving restricted access and distance extension for mobile phone for specific data and apps.
REQ_UC7.1 4	Multicomunicator IP traffic sharing	

Table 6 UC7 related requirements for zero trust services with DLT infrastructure

Zero trust services

Cybersecurity

Factory UID & Dynamic Keys: Each device has a unique **UID** captured during production and stored on the server's allow-list. **AES-128 (CCM)** encryption keys are generated only during the initial registration. All traffic is encrypted and authenticated at the packet level, eliminating protocol overhead.

Multicomunicator radio interface

Broadcast Security & Dynamic LoraID: Radio communication is performed via broadcast. The packet header contains a dynamic **LoraID** (received during registration) which changes if the device is re-registered. Only authorized devices with the matching keys can decrypt and validate the broadcast payload.

Multicomunicator server interface

Stateless Key Retrieval: Upon receiving a broadcast packet, the server uses the **LoraID** from the header to retrieve the specific AES-CCM keys for decryption and integrity checking. DLT infrastructure ensures the integrity of the UID/LoraID registry and provides an immutable log of registration events.

Multicomunicator IP traffic sharing

Authenticated Application Access: The MC-device acts as an intelligent router that converts verified radio broadcasts into IP traffic. Access is granted only to specific mobile apps and data streams that are cryptographically linked to the authorized LoraID/UID profile.

4.4 Sensing of security situation

This section presents the technical enablers developed under T5.4 for sensing security situations across the Sa4CPS use cases. Situational security awareness requires continuous monitoring of both cyber and physical domains to detect anomalies, integrity violations, and potential threats in real-time. The following enablers address diverse security sensing needs – from DNS fingerprint detection and behavioural risk assessment in consumer contexts to operational anomaly detection in industrial logistics, drone operations, and critical infrastructure management.

Enabler	Contributing partners	Addressed Requirements	Related Use Case
DNS Fingerprinting Data Processing Pipeline	F-Secure	REQ_UC5.2 REQ_UC5.3 REQ_UC5.5 REQ_UC5.6 REQ_UC5.7 REQ_UC5.8	UC5
Behavioural Data Hub	F-Secure	REQ_UC5.2 REQ_UC5.3 REQ_UC5.6 REQ_UC5.7 REQ_UC5.8	UC5
Anomalous Data & Integrity Monitor	ISEP	REQ_UC4.1 REQ_UC4.10	UC4
RX Timeslot Monitoring, Uplink Reporting & Isolation	Natlink	REQ_UC7.10	UC7
Real-Time Operational Monitoring and Data Integrity Verification System.	ACD	REQ_UC1.36 REQ_UC1.37	UC1
Continuous monitoring of data integrity, system health and operational consistency	ADLC	REQ_UC8.29, REQ_UC8.32	UC8
Privacy: Protected Identity in UI and REST Security: Data Encryption	Enerim	REQ_UC4.3 REQ_UC4.4 REQ_UC4.5 REQ_UC4.6 REQ_UC4.7 REQ_UC4.8	UC4
Operational Anomaly Detection and Security Situation Awareness in ML-Based Routing Services	Alpata	REQ_UC1.32 REQ_UC1.41	UC1

Table 7 Technical enablers for sensing of security situation

DNS Fingerprinting Data Processing Pipeline (UC5)

In UC5, Security and location awareness of persons, a scalable, cloud-native data processing pipeline has been developed to support DNS fingerprinting research and model development. The pipeline facilitates 1) continuous intake and processing of DNS traffic samples from various sources, 2) transforming raw data into training datasets, and 3) training and validation of DNS fingerprint detection ML models suitable for deployment across diverse environments.

The pipeline implements a sequence of stages:

- 3) The pipeline accommodates continuous DNS data ingestion from a variety of sources (e.g., opt-in clients, control devices, pilot routers, etc.), handling variable volume and velocity constraints inherent in real-world network traffic sample collection. Data samples are ingested into cloud storage infrastructure, which provides a centralized repository accessible to data scientists while maintaining data integrity and traceability throughout the entire pipeline workflow.
- 3) Data processing is implemented in distinct incremental steps:
 - a. **Preprocessing** applies client isolation, normalization, and quality filtering to ensure data consistency and remove any incomplete records.
 - b. **Clustering** combines DNS queries based on set criteria into contextual clusters, representing higher level events that initiated the burst of DNS data. These bursts are the most relevant signals in detecting DNS fingerprints.
 - c. **Manual curation** (optional) allows a human sensor to inspect and/or manipulate automatically created clusters of DNS data. Manual curation of clusters provides a fast track to create fingerprints for e.g., recently emerged malicious applications that need detection as soon as possible.
- 3) Grouping organizes aggregated cluster data by relevant dimensions (e.g., similarity) to facilitate targeted model training. Grouping prepares processed datasets for machine learning experimentation, enabling eventual rapid iteration on detection model development and validation.

Data Accessibility and Experimentation

Processed data is maintained at multiple pipeline stages, allowing data scientists to access intermediate representations suited to different objectives. This staged approach supports both exploratory analysis and controlled validation workflows, enabling model training on appropriately prepared datasets and validation of results with minimal data wrangling.

Model Outputs

The pipeline produces DNS fingerprint detection models tailored for different purposes. On-device detection models are optimized for mobile platforms, respecting computational and memory constraints while maintaining detection accuracy for client-side applications. Router-based detection models are designed for deployment at customer premises equipment (CPE), enabling network-wide visibility and detection capabilities at the network edge for any (W)LAN connected devices, including IoT.

Implementation

The pipeline is implemented on Amazon Web Services using managed service building blocks to minimize operational overhead and support scaling to production volumes. AWS Lambda provides

serverless computation for data intake and transformation steps. Amazon S3 serves as the primary data lake for raw datasets. Amazon DynamoDB enables efficient state management and metadata tracking throughout the pipeline. Amazon SageMaker provides experimentation infrastructure for model development, training, and validation.

Behavioural data hub (UC5)

In UC5, Security and location awareness of persons, the Behavioural Data Hub represents a shift from traditional, perimeter-based cybersecurity toward a human-centric protection model. Rather than treating security as a set of isolated tools (firewalls, scanners, or warnings), the hub places the user at the center and understands risk as something that emerges from behaviour, context, and exposure over time.

Modern users move fluidly across multiple digital moments every day—browsing online, communicating via messages, managing personal data, maintaining devices, and responding to awareness signals. Each of these moments generates behavioural signals that, in isolation, may seem benign, but when connected reveal meaningful risk trajectories.

The Behavioural Data Hub acts as a unifying layer that:

- Aggregates behavioural signals across browsing, messaging, personal data usage, device hygiene, and awareness interactions
- Normalizes these signals into comparable, privacy-respecting features
- Connects protection touchpoints (e.g., scam detection, password vaults, device scanning) to observable behavioural outcomes

Privacy-by-design & trust enablers

- Consent and purpose-limited collection
- Data minimization + on-device feature extraction
- Pseudonymization and linkability controls
- Privacy-preserving analytics for benchmarking (“compared to peers”)

Risk scoring, modelling, and governance

- Feature store
- Hybrid risk engine (rules + ML)
- Model governance and evaluation
- Explainability for user-facing insights

Integration with “Our protection abilities”

- Messaging protection signals (SMS + instant messaging)
On-device classification, link reputation checks, scam pattern features, minimal-content collection by default.
- Browsing/online protection signals (browser/desktop extensions)
- Personal data protection (identity monitoring, password vault)
- Device hygiene (scanning, OS status, device lock, privacy advisor)
- Awareness & motivation (scam scanner/deep fake detection, news/education)

Anomalous Data & Integrity Monitor (UC4)

In UC4, this enabler monitors incoming IoT streams for data gaps or injections. It triggers the "Missing data replacement" logic when sensors fail or are attacked, ensuring the grid operator always has a synthetic or estimated baseline to prevent operational failure.

Related requirements from D5.1 are REQ_UC4.1 Missing data replacement and REQ_UC4.10 IoT Data Retrieval.

Privacy: Protected Identity in UI and REST (UC4)

In UC4, EnerimCIS implementation for protected identity customers to ensure that only authorized users can view and manage these customers. The implementation shall encompass processes, user interface views, customer documents, invoices, and REST APIs.

Security: Data Encryption (UC4)

In UC4, encrypting data in transit is a fundamental security measure to protect sensitive information and maintain the trust and integrity of communication systems for several reasons:

- **Confidentiality:** Encryption ensures that sensitive data remains confidential while being transmitted over networks. Unauthorized parties cannot read the data without the decryption key.
- **Integrity:** Encryption helps protect data from being altered or tampered with during transmission. It ensures that the data received is the same as the data sent.
- **Authentication:** Encryption can help verify the identity of the parties involved in the communication, ensuring that data is being sent and received by the intended parties.
- **Compliance:** Many industries have regulations and standards (such as GDPR, HIPAA, and PCI-DSS) that require encryption of data in transit to protect sensitive information.
- **Protection Against Attacks:** Encryption helps protect against various types of cyber attacks, such as man-in-the-middle attacks, eavesdropping, and data breaches.

We will enhance the security of EnerimCIS by encrypting data in transit between EnerimCIS UI and Facade.Main backend.

Multicomunicator radio interface: RX Timeslot Monitoring, Uplink Reporting & Isolation (UC7)

In UC7, device could detect if it gets commands in receiving timeslot which it can not open and inform it to uplink. Which can be caused by wrong configuration or designed attack.

- **RX Timeslot Monitoring:** The device monitors its receiving timeslot for any data with an invalid **LoraID** or payloads that cannot be decrypted (AES-CCM MIC failure).
- **Uplink Reporting:** If the device receives commands in its timeslot that it cannot open, it immediately informs the server via an uplink message. This diagnostic data allows the system to distinguish between a "wrong configuration" and a "designed attack."
- **Isolation:** Invalid packets are discarded at the RAM level to prevent them from affecting the device's state or wasting processing power.

Continuous monitoring of data integrity, system health and operational consistency (UC1)

UC8: The platform senses the security situation through continuous monitoring of both data quality and system behaviour. This monitoring is implemented as part of the worker processing and rule evaluation pipeline.

The system continuously checks:

- whether data sources are alive and providing data at expected frequencies,
- whether values remain within plausible physical and operational bounds,
- whether multiple sources remain mutually consistent (e.g. telemetry vs. expected flight path or environment),
- and whether communication or processing delays exceed acceptable thresholds.

Loss of telemetry, abnormal changes, inconsistencies, or unexplained deviations are explicitly detected and raised as abnormal events, with appropriate severity levels. These events are then integrated into the same risk and alert streams as physical anomalies, making cyber-physical degradation visible within the operational risk model.

This directly supports the requirement for real-time situational awareness and timely response, and enables early detection of denial-of-service conditions, data manipulation attempts, or infrastructure degradation that could compromise operational safety.

Sensing of security situation during in-factory forklift operations (UC1)

In UC1, Otokar contributes to sensing the security situation by monitoring both **physical safety conditions** and **cyber-physical operational states** during in-factory forklift operations. The focus is on detecting potentially hazardous situations involving human–machine interaction, especially during autonomous or semi-autonomous forklift maneuvers.

The forklifts are equipped with **Time-of-Flight (ToF) cameras** mounted on the front and rear sides, enabling real-time perception of the surrounding environment. Sensor data is processed locally using **edge computing platforms**, where AI-based perception algorithms identify human presence and estimate the distance between forklifts and nearby workers.

Based on predefined safety thresholds, the system continuously evaluates the risk level of the current situation. When a human is detected within a safe distance, the system operates in a normal monitoring state. As the distance decreases below configured thresholds, the system transitions to “**Warning**” and subsequently “**Danger**” states. These states represent escalating security and safety risks that require immediate attention.

Security-related events, such as danger-level proximity, are communicated to the forklift operator through **visual alerts**, including a red warning light inside the operator cabin. At the same time, abstracted security events can be logged or transmitted to backend systems for further analysis and auditing. This approach ensures timely local response while supporting higher-level situational awareness.

By combining real-time sensing, AI-based analysis, distance-aware risk assessment, and immediate feedback mechanisms, UC1 demonstrates an effective approach to sensing and responding to security situations in industrial logistics environments. This capability directly supports the Sa4CPS objectives of proactive risk detection, cyber-physical resilience, and safe autonomous operations.

Real-Time Operational Monitoring and Data Integrity Verification System (UC1)

This technical enabler detects security status in two layers:

- 1) The ELK Stack infrastructure provides operational monitoring by collecting and analyzing high-volume data in real time.
- 2) IPFS and Blockchain integration continuously monitors data integrity. When the CID value of a file called from IPFS is recalculated and compared with the record on the blockchain, any discrepancy immediately reveals an unauthorized change (security breach) in the data.

This technical enabler addresses UC1 Autonomous lightweight logistics.

Operational Anomaly Detection and Security Situation Awareness in ML-Based Routing Services (UC1)

ALPATA contributes to the sensing of the security situation by enabling real-time monitoring and anomaly detection within its ML-based routing and vehicle coordination services. Although ALPATA does not implement dedicated cybersecurity products, the routing engine continuously observes operational data flows and system behaviour to identify deviations that may indicate potential security incidents.

The enabler processes real-time IoT data streams, including vehicle positions, speed, payload status, and routing requests. Consistency checks and validation rules are applied to incoming data to detect abnormal patterns such as contradictory location updates, unexpected routing commands, or unauthorized attempts to influence route computation.

Machine learning models used for delay and congestion prediction also contribute to security situation awareness by detecting unexpected operational patterns. Sudden deviations from learned traffic or movement behaviour may indicate malfunctioning sensors, compromised data sources, or unauthorized system interactions.

In addition, access control mechanisms restrict which backend services are allowed to trigger routing decisions, while vehicles are limited to reporting their own operational status. Rejected or suspicious requests are logged and flagged, enabling early identification of potential security risks in safety-critical logistics operations.

Through this approach, ALPATA's routing enabler supports continuous sensing of the operational security situation by combining real-time monitoring, anomaly detection, and controlled system interactions.

4.5 Credential-based trust system

The project story requires some solutions, e.g., for identification, verification and access control (task 5.1). To support this need, VTT has investigated into enabler called here as *credential-based trust system*. Trust system is planned to have secured access control and API for different stakeholders which can be applied for example users and devices. Access to key resources will be secured by using verifiable credentials stored in wallet. Trust system provides a possibility for stakeholders to visualise trust status. Trust system will store the history of the critical events like credentials and alarms and provides possibility for browsing the history. Figure 3 shows overview of the trust system.

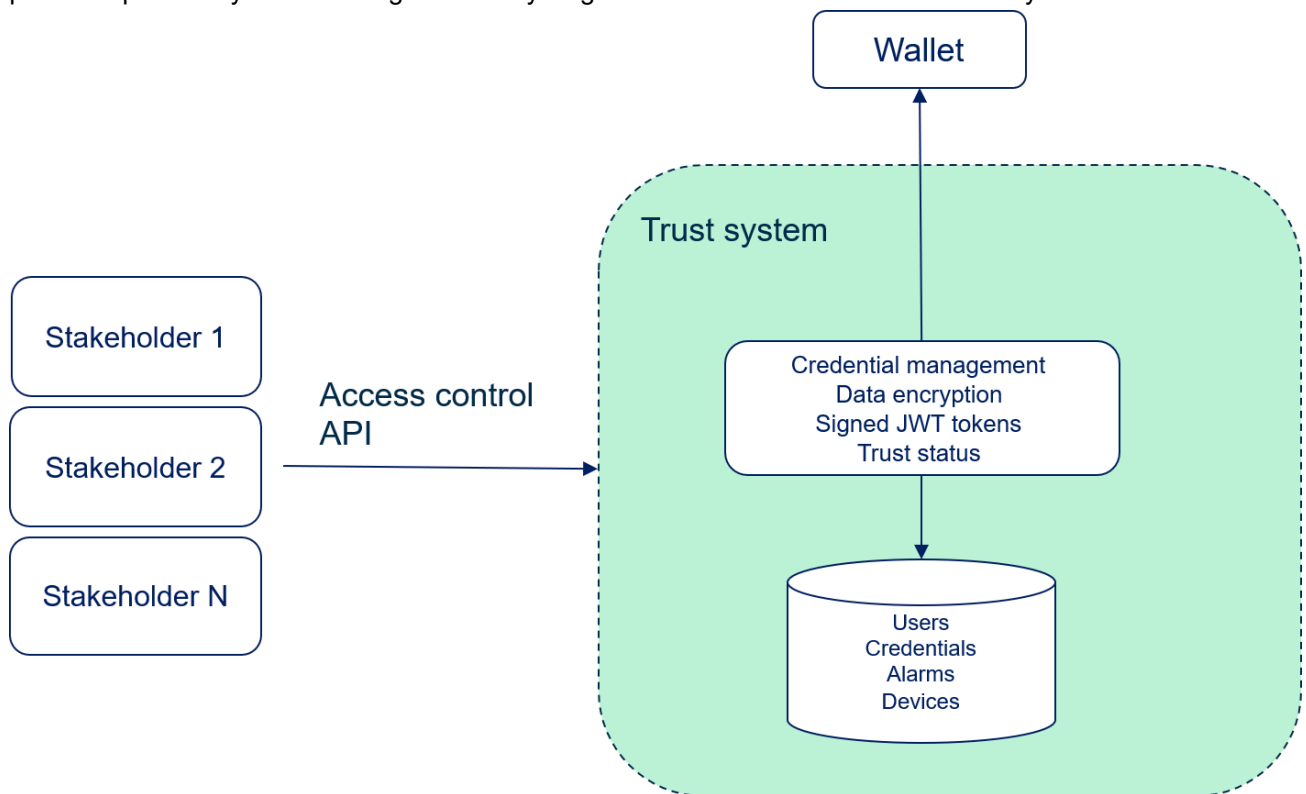


Figure 3. Trust system

The *credential-based trust system* needs several lower level technical enablers shortly described in the following:

Management of secrets

Any secrets that are used within the system, including both backend and frontend of the trust system, are kept secure as well as possible. Exposing secrets, such as private keys or passwords, in frontend applications is insecure, thus implementations of cryptographic algorithms are centralized to the backend. If some secret cannot be avoided to be used in the frontend application, such as the access and refresh tokens, those shall be session only and saved only in the browser's session storage. The session storage will be cleared after every session is terminated. If any secrets are used in the backend application, the secrets are accessed using environment variables for an extra layer of protection.

Role-based access control (RBAC)

RBAC is a method for access control inside applications and software, that handles and limits access rights to for example, web pages, data, API endpoints and other functionalities based on the role of the user in the system. RBAC will be used to control access rights to data and functionalities. Trust system will be using RBAC to separate different roles like administrator, maintenance person, first responder, customs agent, carrier, driver, supplier and visitor for their functionalities and user interfaces.

Credential-based access control (CBAC)

Similarly to RBAC, Credential Based Access Control will handle, and limit access rights based on the verifiable credentials the user holds. Trust system will be CBAC to manage access pass control, location tracking, messaging control between users, health data information, device information, delivery information and driving permission.

Credential management

For credential management, trust system will be using walt.id wallet platform. Walt.id provides a full-stack digital identity infrastructure for issuing, storing, and verifying credentials. It supports standards like W3C verifiable credentials, ISO mDocs, and SD-JWT verifiable credentials, and exposes APIs and SDKs for issuers, wallets, and verifiers. For credential issuance walt.id support OpenID4VCI protocol and multiple formats (W3C credentials, SD-JWT credentials, ISO mDL/mDoc, OpenBadge, eIDAS2 compliant credentials). W3C verifiable credentials are selected to be used in trust system. Walt.id issuer API stores, manage, and present credentials in a secure way. It supports OpenID4VP protocol for credential presentation. Walt.id wallet is available as white-label application and can be embedded into existing platforms. Trust system stores credentials in wallet, but wallet GUI is not planned to use actively. Instead, trust system is planned to have custom GUI to show credential information. Walt.id credentials are verified against issuer metadata and trust frameworks. Verification works with any wallet that supports OID4VP. Credential key management services (KMS) enable keys to be used with credentials to be stored safely in external systems. When accessing credentials with KMS, walt.id handles only credential metadata and content, private keys never leave the secure KMS environment, reducing the risk of private key exposure. Walt.id supports for example HashiCorp Vault, Azure Key Vault, Oracle KMS and AWS KMS providers. All supported KMS providers are commercial, trust system is planned to store keys in wallet itself.

Symmetric encryption

Some of the data that is being handled in the backend server can be encrypted. Symmetric encryption could be used as all the servers that require the encrypted data are in the same virtual machine. Thus, agreeing on sharing one secret key to be used for encrypting and decrypting processes is sufficient. Project solution will be using the Advanced Encryption Standard (AES) for encryption. From the many variants, the AES-256 in CBC mode is used, as it uses a 256-bit key that also ensures security against quantum computers when they mature. The AES-256 requires using a 128-bit initialization value (IV), that is also saved together with the encrypted data to be able to decrypt it. Security on this scheme relies on not reusing the IV's and keeping the secret key tightly secure. These encryption functions shall not be used directly in frontend applications, as the frontend applications load the secret key into the browsers memory, thus making it possible for it to be exposed and leaked.

Signed JWT tokens

Trust system will provide an application programming interface (API), for example for internal use and accessing credential data by other components. API will be using signed JWT tokens for access and refresh tokens. The JWT tokens are generated by first generating the payload that travels inside them and then signing the token with a secret key by using the RS256-algorithm. The RS256 algorithm will require the token receiver to validate the JWT signature using the public key from the private-public key pair, from which the private key was used to sign the JWT token. Both access tokens and refresh tokens are generated similarly, with different lifetimes. When verifying the access token upon every API request, the validity will be ensured using the API middleware that verifies the signature and the lifetime. Every API request will be denied if the

access token has died, or the signature couldn't be verified. The access token and refresh tokens are returned to the logged in user in the endpoint response. The refresh token will also be saved to the database together with the user information, to be used together with the access token refresh endpoint.

Conclusions

This deliverable has presented a comprehensive specification of technical enablers for trust, security, and privacy developed within Work Package 5 of the Sa4CPS project. The enablers address fundamental security challenges in cyber-physical systems where autonomous devices, human operators, and external stakeholders must interact reliably and securely to achieve effective situational awareness in safety-critical environments.

The technical enablers span four complementary trust, security and privacy domains: identification, verification, and access control (Task 5.1); secure information spaces, sharing, and routing (Task 5.2); zero-trust services with distributed ledger technology infrastructures (Task 5.3); and sensing of security situations (Task 5.4).

The enablers specified in this deliverable provide the technical foundation for secure situational awareness in the Sa4CPS concept. The next phase of work, documented in Deliverable 5.3, will focus on the design of these enablers.